



ML10:2023 – Model Poisoning

OWASP Machine Learning Top 10

Francesco Maria Torino

Mat.: 0522501879

E-mail: f.torino1@studenti.unisa.it

Introduzione



OWASP (Open Web Application Security Project) è una fondazione no-profit che promuove la sicurezza del software attraverso:

- progetti open-source,
- community globali,
- standard di sicurezza,
- formazione e conferenze.

Produce documenti fondamentali come l'OWASP Top 10, incluso il nuovo ML Top 10, che identifica le principali vulnerabilità nei sistemi di Machine Learning.

ML10:2023 Model Poisoning

È una delle **vulnerabilità (fault di sicurezza)** della **OWASP Machine Learning Top 10** e occupa una posizione elevata perché colpisce direttamente un modello di ML.
È pericolosa perché **difficile da rilevare, può introdurre errori persistenti negli output e ha un impatto elevato su sistemi critici.**



Definizione di Model Poisoning

Model Poisoning = manipolazione intenzionale dei parametri del modello per alterarne il comportamento.



Come viene attaccato il modello?

L'attacco viene messo a segno in quattro modi principalmente:

1. Vengono **modificati i pesi** del modello;
2. **Alterare le predizioni** del modello (misclassification)
3. Inserire **comportamenti nascosti** (backdoor)
4. **Degradare** deliberatamente le **prestazioni** del modello (sabotage)



Model Poisoning

Esempio di Model Poisoning

Scenario di Attacco pubblicato su OWASP — Profitto finanziario tramite Model Poisoning

Una banca utilizza un modello di machine learning per riconoscere i caratteri scritti a mano sugli assegni e automatizzare la fase di verifica.

Il modello è addestrato su un grande dataset di esempi e riconosce i caratteri in base a parametri come dimensione, forma, inclinazione e spaziatura.

Un attaccante può avvelenare (**poison**) il modello alterando direttamente i parametri del modello.

In questo modo il modello riconosce alcuni caratteri in maniera sbagliata: ad esempio potrebbe interpretare il numero “5” come “2”.

Sfruttando la manipolazione, l’attaccante può inserire assegni falsificati che vengono considerati validi dal sistema, causando **ingenti perdite economiche** alla banca.

Tipi di Model Poisoning

Regularisation

Applicare tecniche come **L1** o **L2 regularization** nella loss function.
Aiuta a prevenire l'overfitting e rende il modello **meno sensibile a perturbazioni artificiali** introdotte dagli attaccanti.



Tipi di Model Poisoning

Robust Model Design

Utilizzare **architetture robuste** e funzioni di attivazione stabili.
Integrare tecniche come adversarial training e gradient masking.
Riduce la probabilità che modifiche maliziose influenzino significativamente il comportamento del modello.



Tipi di Model Poisoning

Cryptographic Techniques

Firmare digitalmente i modelli e verificarne l'integrità (hashing).

Proteggere i file dei pesi con controlli di accesso rigidi.

Evita che soggetti non autorizzati possano **accedere, modificare o sostituire** i parametri del modello.



Risk factor identificati da OWASP

Exploitability: 5 – Easy

L'attacco è facilmente realizzabile da attori con competenze ML.

Detectability: 3 – Moderate

Le manipolazioni dei parametri sono spesso subdole e difficili da identificare nei test standard.

Technical Impact: 3 – Moderate

- Le predizioni del modello possono essere manipolate.
- Informazioni sensibili apprese dal modello possono essere estratte.
- Le decisioni automatiche vengono influenzate negativamente.
- Danni alla reputazione dell'organizzazione.

CWE's Correlati

CWE	Descrizione
CWE-20	Improper Input Validation
CWE-74	Injection
CWE-354	Improper Validation of Integrity Check Value
CWE-347	Improper Verification of Cryptographic Signature
CWE-732	Incorrect Permission Assignment
CWE-522	Insufficiently Protected Credentials
CWE-1295	Security Issues in Federated Learning
CWE-1296	Federated Learning Poisoning Vulnerabilities

Grazie per l'attenzione!

